

WORLD-CLASS

HRIS / HCM SYSTEM BLUEPRINT 2026

Product Strategy • Complete Feature Catalogue • Data Model • Roles & Permissions • UX/UI Design System • Security • UAE Pack • Implementation Roadmap

Target stack	Python / Flask • MySQL • HTML • CSS • JavaScript
AI development agent	OpenAI Codex
Deployment target	Ubuntu Server
Research date	09 September 2026

Goal: build an HR platform where HR cannot reasonably say “that function is missing”, while keeping the product usable, secure, configurable and maintainable.

Blueprint Contents

A-to-Z product map for the HRIS/HCM build. Use the numbered chapters as implementation workstreams and acceptance checkpoints.

1. Executive Summary	14. UX/UI Design System - Exact Recommendation
2. 2026 Market Benchmark	15. Technical Architecture for Python / MySQL / HTML / CSS / JS
3. Product Principles and Boundaries	16. Security, Privacy and Audit Controls
4. Roles, Personas and Permission Model	17. Reporting, Metrics and Dashboard Catalogue
5. Complete Module Catalogue	18. AI and Codex Strategy
6. Employee Lifecycle State Model	19. Non-Functional Requirements and System Limits
7. Data Model Blueprint and MySQL Type Conventions	20. Recommended Implementation Roadmap
8. Employee Data Dictionary - What to Capture	21. Release Gates
9. Workflow and Approval Engine Specification	22. Practical Build Order - Database to UI
10. Official HR Documents and PDF Outputs	23. Feature Acceptance Matrix
11. Payroll and Compensation Engine - Detailed Design	24. Research Sources and Standards
12. Performance and Appraisal Design	25. Final Product Recommendation
13. UAE Country Pack - Configuration Requirements	

1. Executive Summary

This is a product blueprint, not a generic HR feature checklist. It is designed for an existing Python HR application that should be upgraded in-place rather than casually rebuilt.

Core recommendation Build a unified HCM platform around one trusted people data model, a reusable workflow engine, a strict permission/audit layer, document automation, and role-based employee/manager/HR experiences. The market leaders differ in style, but they converge on those foundations.

What “world-class” means in 2026

- One source of truth for people, organizations, positions, employment, compensation, time, documents, skills and lifecycle events - not separate tables that drift out of sync.
- End-to-end lifecycle: plan headcount → recruit → hire → onboard → work/time/leave → pay/reward → perform/develop → move/promote → offboard/alumni.
- Role-based self-service so employees and managers complete routine work without HR becoming a manual help desk.
- Configurable workflows and approvals. Policies should be data, not hard-coded Python branches scattered through routes.
- Real-time reporting and historical “as-of” reporting, with an audit trail for every sensitive change.
- Country and legal-entity localization. Rules such as leave, overtime, payroll and final settlement must be configurable by jurisdiction and effective date.
- A modern, calm SaaS interface: fast navigation, excellent tables/forms, visible status, contextual actions, timelines, drawers, dashboards and mobile-responsive workflows.
- Security appropriate for payroll, identity documents and employee records: MFA/SSO-ready, least privilege, field-level restrictions, encryption, immutable audit, secure documents and export controls.
- AI used as an assistant over trusted permissions and structured data - not as an uncontrolled replacement for deterministic payroll or approval logic.

Recommended product positioning

Area	Recommendation
Product shape	Full HRIS/HCM platform with modular activation; keep a single codebase and data foundation at first.
Primary personas	Employee, Manager, HR, Payroll/Finance, Recruiter, Talent/L&D, Executive, Auditor, IT/Asset Admin.
Architecture	Modular Flask monolith + clear service boundaries + async worker + API/webhooks. Avoid premature microservices.
Frontend	Custom design system using HTML/CSS/JavaScript. No “default Bootstrap CRUD” appearance.
Database	MySQL 8; normalized core tables, effective-dated history, JSON only for truly dynamic metadata.
Documents	Versioned template engine + generated PDFs + private storage + e-signature/status + audit.
UAE readiness	WPS-oriented payroll outputs, visa/Emirates ID/work permit expiry, gratuity/final settlement, UAE leave/overtime policy packs, bilingual-ready templates.
Roadmap strategy	Foundation first; then payroll/time/docs; then talent/recruiting; then analytics/AI/integrations.

2. 2026 Market Benchmark

The system should not copy any vendor. Use the market to understand what sophisticated buyers now expect.

Platform	What it demonstrates	Design lesson for your system
Workday	Unified core HR, payroll, absence/workforce management, compensation, benefits, analytics, skills and employee experience with embedded AI.	Treat people data, process and analytics as one platform; build “single source of truth” first.
SAP SuccessFactors	Global core HR/payroll plus recruiting, onboarding, learning, performance/goals, compensation and AI-assisted HR.	Support global/country rules and deep talent processes; use effective-dated configuration.
Oracle Fusion HCM	Unified data/security, HR, talent, workforce management, payroll, analytics, HR Help Desk and personalized Journeys.	Add guided lifecycle journeys and an HR service desk rather than forcing users to know the correct module.
Rippling	Strong lifecycle automation, global HRIS, recruiting, performance, learning, time, permissions and links to identity/devices.	Make employee changes trigger downstream actions automatically; permissioning must be granular.
BambooHR	Simple employee experience with connected HR data/reporting, hiring/onboarding, payroll/time, benefits, performance, compensation and compliance.	Enterprise capability does not require enterprise complexity in the UI.
HiBob	Modern UX across core HR, time, payroll hub, onboarding, performance, surveys, compensation, planning and culture.	Human-centered experience, visible org context and flexible workflows matter as much as raw features.
Deel	Global worker lifecycle, hiring, HR data, documents, time off, payroll/compliance and international workforce operations.	Model employees, contractors and location/currency/legal-entity localization cleanly.
Zoho People	Broad operational HR: onboarding, employee database, documents, leave, attendance, timesheets, performance, compensation, engagement, analytics and cases.	A complete mid-market platform needs operational breadth and good configuration at reasonable complexity.

Market pattern The strongest products repeatedly emphasize connected data, self-service, automation, analytics, global/local compliance and embedded AI. Your competitive advantage should be a cleaner implementation of those ideas for your target organizations, not simply a longer sidebar.

World-Class HCM Capability Map

One people data foundation; every module connected through workflows, permissions and analytics.



Figure 1 - Recommended HCM capability map.

3. Product Principles and Boundaries

Principle	Rule
System of record	Every business-critical employee fact has one canonical owner and a history.
Configuration over code	Leave rules, approval chains, document templates, grades, salary components and policies must be configurable.
Effective dating	Future/past changes should be scheduled with effective_from/effective_to where appropriate.
No destructive HR deletes	Employment, salary, approvals, payslips and disciplinary history are archived/versioned, not casually deleted.
Least privilege	Access is deny-by-default and scoped by role + legal entity + hierarchy + sensitivity.
Explainable automation	Every automatic action shows why it happened, which rule fired and what changed.
Human approval for high-risk actions	AI can prepare, summarize or validate; payroll close, termination, salary changes and legal letters require deterministic controls/authorized approval.
Mobile-aware, desktop-strong	Employees should complete common tasks on mobile; HR power workflows remain excellent on desktop.
Accessible by design	Target WCAG 2.2 AA for contrast, keyboard usage, focus, error messaging and scalable text.
API-ready	Do not make integrations scrape HTML. Build stable service/API boundaries even if the first UI is server-rendered.

4. Roles, Personas and Permission Model

Recommended standard roles

Role	Primary scope	Typical capabilities / limitations
Platform Super Admin	All tenants/system	Infrastructure/configuration; no routine need to view payroll/medical content. Use break-glass access.
Tenant / Company Admin	Company/legal entities	Company setup, modules, master data, role assignment; not automatically payroll-visible.
HR Director / Head of HR	All HR data for assigned entities	Strategic HR, approvals, talent, reports, sensitive cases; payroll access configurable.
HR Admin / HR Officer	Assigned entities/locations	Employee lifecycle, documents, leave, requests, cases, onboarding/offboarding.
Payroll Admin	Assigned payroll groups	Salary structures, variables, payroll run, payslips, final settlement, WPS export; no medical-case content unless separately granted.
Finance Approver	Assigned cost centers/entities	Payroll totals, reimbursements, loans, budget approvals; mask unrelated personal data.
Recruiter	Open requisitions/candidates	ATS, offers, interview process; no employee salary history unless role requires it.
Performance / Talent Admin	Assigned population	Review cycles, calibration, succession, goals, competencies, PIP.
L&D Admin	Assigned population	Courses, enrollments, certifications, training budgets/compliance learning.
Manager	Direct/indirect reports per policy	Team profile subset, approvals, performance, time, goals. No bank IDs, passports, medical docs or peer salaries.
Department Head	Department hierarchy	Wider people analytics and approvals, but still sensitivity-limited.
Employee	Self	Self-service data, requests, documents, payslips, goals, learning, feedback, personal timeline.
Executive / Leadership	Aggregate + approved drill-down	Headcount, cost, attrition, talent metrics; strong restrictions on individual-sensitive details.
Auditor / Compliance	Read-only scoped	Audit trail, policy evidence, selected documents/reports; no write/delete.
IT / Asset Admin	Assets + access tasks	Device/access assignment and offboarding tasks; minimal HR profile data.
Integration Service Account	API scope only	Machine-to-machine permissions, IP/secret controls, no interactive login.

Use RBAC + scope + attributes, not role names alone

- Role-based access control (RBAC): what actions a role can perform.
- Scope: which legal entity, branch, department, team or employee population is visible.
- Hierarchy: direct reports, all descendants, dotted-line reports, project team, or none.
- Data sensitivity: public directory, internal, confidential, highly restricted (payroll/bank/medical/disciplinary).
- Action sensitivity: view, create, update, approve, export, download, print, bulk action, impersonate, configure.
- Context: temporary delegation, acting manager, payroll cut-off, probation period, country, employment type.

Important “Manager” must never mean “can see the full employee row”. The employee profile should be assembled from fields/sections the current user is authorized to see.

5. Complete Module Catalogue

The following scope is intentionally broader than a basic HRMS. Build it as modules over a shared foundation; do not try to ship every module in one sprint.

5.1 Core HR, Organization & Employee Master

- Employee/person master with employee number, preferred/legal name, photo, contacts, demographics, nationality/citizenship, emergency contacts, dependents and configurable custom fields.
- Company → legal entity → business unit → branch/location → department → team hierarchy; cost centers and profit centers.
- Job architecture: job family, job function, job title, grade/level, position, FTE, reporting line, dotted-line manager, position status.
- Employment records: employee/contractor/intern/consultant; full-time/part-time/temporary/flexible/remote/job-share; start/end dates; probation; notice period; contract details.
- Lifecycle actions: hire, rehire, transfer, promotion, demotion, manager change, location change, contract renewal, status change, suspension, resignation, termination, retirement, death in service.
- Effective-dated history and a human-readable employee timeline; never overwrite history without a correction audit.
- Org chart, employee directory, search, saved filters, bulk import/export, duplicate detection and data quality checks.
- Field-level data classification and profile-section visibility by role.

5.2 Employee & Manager Self-Service

- Employee dashboard, profile update requests, leave/time, requests, payslips, letters, documents, benefits, goals, learning, surveys, recognition and personal tasks.
- Manager dashboard: team status, approvals, attendance exceptions, leave calendar, probation/review deadlines, document expiries and team analytics.
- Delegation/acting manager periods; approval proxy with full audit.
- Global search plus quick actions ("Request leave", "Generate salary certificate", "Add employee", "Start transfer").
- Inbox/task center that combines approvals, acknowledgements, required documents, review tasks and escalations.

5.3 Recruiting / Applicant Tracking System (ATS)

- Headcount/requisition request with budget, position, replacement/new headcount, reason, target start date and approval.
- Career page/job posting, source tracking, referral, agencies, candidate pool/talent community.
- Candidate profile, CV/attachments, consent, screening questions, tags, notes and duplicate detection.
- Pipeline stages configurable per role: applied → screen → assessment → interview → offer → hired/rejected/withdrawn.
- Interview panel scheduling, scorecards, structured feedback, conflict/late feedback reminders.
- Offer builder, approval, versioning, e-signature, expiry, negotiation log and pre-employment checklist.
- Convert candidate to worker without retyping identity data; preserve recruiting source and history.
- Metrics: time-to-fill, time-to-hire, source effectiveness, offer acceptance, stage conversion, diversity metrics where lawful.

5.4 Onboarding, Crossboarding & Offboarding Journeys

- Template-based journeys by company, country, role, branch, employment type and seniority.
- Preboarding: personal data, bank/tax data, contracts, policy acknowledgements, IDs, medical/insurance forms and document collection.

- Task owners across HR, Manager, IT, Finance, Facilities and employee; due dates relative to start/end date.
- Assets, email/system access, desk, phone/SIM, uniforms/PPE, training and buddy assignment.
- 30/60/90-day milestones, probation objectives and confirmation review.
- Crossboarding for transfers/promotions/location changes with only relevant tasks.
- Offboarding: resignation/termination workflow, notice, leave settlement, final payroll, asset return, access removal, exit interview, experience/service letter and alumni status.
- Rehire eligibility and reason; preserve all history across rehire.

5.5 Leave & Absence Management

- Leave types with entitlement rules, accrual, front-loading, carry-forward, expiry, negative balance, encashment and prorating.
- Full-day, half-day, hourly leave; calendar-aware working days, weekends, public holidays and shifts.
- Eligibility by legal entity, country, grade, tenure, gender where lawful, employment type and probation.
- Attachments/medical certificate rules; restricted visibility for medical files.
- Multi-step approval, auto-approval rules, delegated approver, cancellation, amendment, return-from-leave and leave recall.
- Balance ledger: every accrual, deduction, adjustment, carry-forward and encashment as a transaction, not just one mutable balance number.
- Team calendar, blackout dates, minimum staffing rules and overlap warnings.
- Leave liability reporting, absence trends and unusual pattern alerts.

5.6 Time, Attendance, Shifts & Scheduling

- Shift templates, rotating rosters, flexible schedules, split shifts, rest days, holidays and Ramadan/seasonal schedules.
- Clock in/out from web/mobile/biometric imports; manual correction request with approval and audit.
- Late/early/absence rules, grace periods, breaks, missed punch handling and attendance regularization.
- Overtime request/pre-approval, actual overtime, rule-based calculations and compensatory time.
- Timesheets by project/cost center/job where needed; billable/non-billable.
- Manager scheduling, shift swap request, availability and understaffing warnings.
- Payroll handoff of approved hours, overtime, unpaid leave and exceptions.
- Do not require GPS/geofencing unless there is a real business need and a documented privacy basis.

5.7 Payroll, Salary, Compensation & Rewards

- Salary structure: basic, fixed allowances, variable earnings, overtime, commission, bonus, deductions, benefits, employer contributions and one-offs.
- Compensation history with effective dates, reason, approver, currency, FTE and annual/monthly/hourly normalization.
- Payroll groups, pay periods, cut-off, draft → validate → approve → lock → pay → publish payslips → accounting/export.
- Variable input import, retro adjustments, proration, unpaid leave, overtime, loans/advances, reimbursements and deductions.
- Payslip versions, secure employee download, private storage, generation status and audit.
- Compensation review cycles, merit matrix, promotion increases, salary bands, compa-ratio, budget pools and approval.
- Bonus/incentive plans and eligibility; sales commission can be a separate advanced engine.
- Final settlement: unpaid salary, leave encashment, gratuity/end-of-service, deductions, notice recovery/pay, tickets or other contractual items.
- Payroll reconciliation, exception reports, variance vs previous period and maker-checker controls.
- General ledger/export mappings and WPS/bank file outputs as country-specific adapters.

5.8 Benefits, Insurance & Employee Financial Programs

- Benefit plans, eligibility, enrollment window, employer/employee contribution, dependents, plan documents and effective dates.
- Medical/life insurance tracking, policy/member numbers, insurer, coverage dates and expiry alerts.
- Loans/salary advances with approval, installment schedule, balance, payroll deduction and settlement.
- Air ticket/annual travel entitlement where company policy provides it: eligibility, route/class, request, reimbursement/booking, balance/history.
- Allowances (housing, transport, phone, education, relocation) with eligibility and payroll integration.
- Reimbursements/claims with categories, receipts, policy limits, approvals and finance export.

5.9 Documents, Letters, Certificates & e-Sign

- Private employee document vault with categories, versions, effective/expiry dates, tags, source, access level and retention rule.
- Template engine with placeholders and conditional blocks; preview before issue; PDF generation and version hash/reference.
- Salary certificate, salary transfer letter, employment certificate, NOC, experience/service letter, promotion/transfer letter, probation confirmation, warning letters, leave confirmation, offer/contract, payslip, final settlement and custom letters.
- Approval-before-issue for sensitive/legal documents; issued-by and signed-by metadata.
- e-signature status, acknowledgement, read receipt and policy acceptance tracking.
- Expiry alerts for passport, visa, Emirates ID, work permit, insurance, licenses, certifications and contracts.
- Never expose a direct public file path; use authorized download endpoints or short-lived signed URLs.

5.10 Performance, Appraisals, Goals & Talent

- Review cycle builder: annual, probation, project, quarterly, 180/360, manager-only, employee self-review.
- Goal/OKR/KPI library with cascading goals, weights, targets, progress, evidence and check-ins.
- Competency framework by job family/grade; behavioral and technical competencies.
- Continuous feedback, praise, request feedback, private manager notes, 1:1 agenda/action items.
- Review forms with sections, scales, comments, attachments, acknowledgements and sign-off.
- Calibration sessions and 9-box talent grid; promotion/readiness recommendations with evidence.
- Performance Improvement Plan (PIP): reason, goals, milestones, support, review dates, outcomes and approvals.
- Succession planning, critical roles, successors, readiness, risk of loss and development actions.
- Career paths/internal mobility and skill gap views; link development actions to learning.

5.11 Learning, Skills & Certification

- Course/catalog, internal/external provider, modality, duration, cost, prerequisite and audience rules.
- Enrollment, approvals, waitlist, completion, score, attendance, feedback and certificates.
- Mandatory/compliance training with due/expiry dates and escalation.
- Skills taxonomy/proficiency, skill evidence, certifications/licenses, expiry and renewal.
- Individual development plans tied to performance reviews and career goals.
- Training budget and cost reporting by employee/department/location.

5.12 Employee Experience, Surveys & Recognition

- Pulse, engagement, onboarding, exit and custom surveys; anonymous/confidential modes with minimum response threshold.
- eNPS/engagement trends and action plans; never expose individual anonymous responses.
- Recognition/kudos linked to company values; optional points/rewards with moderation.
- Announcements/news feed, policy updates, birthdays/work anniversaries with privacy controls.

- Employee suggestions/ideas and lightweight polls.

5.13 HR Service Desk, Requests, Grievance & Disciplinary

- Generic "Other Requests" should evolve into configurable HR service categories with forms, SLA, routing, priority and status.
- Employee cases: letter request, data correction, payroll query, benefits, travel, asset, access, workplace concern and general HR inquiry.
- Confidential grievance/complaint workflow with restricted case team and evidence; whistleblowing can be a separately hardened channel.
- Disciplinary case: allegation, investigation, meetings, evidence, findings, actions, warnings, appeal and closure.
- Case notes, internal-only comments, employee-visible comments, attachments, ownership, SLA timers and escalation.
- Knowledge base and guided answers before a ticket is submitted.

5.14 Workforce Planning & Position Control

- Approved positions with status: planned, open, frozen, filled, abolished; headcount and FTE controls.
- Annual/quarterly headcount plan by entity/department/cost center/grade/location.
- Budgeted salary range and total employment cost; compare plan vs actual vs forecast.
- Vacancy/requisition creation from an approved position.
- Scenario planning for growth, restructuring and replacement.
- Critical role and succession risk dashboard.

5.15 Health, Safety, Incident & Wellbeing (Optional but enterprise-grade)

- Workplace incident/injury report, location, severity, witnesses, immediate actions, attachments and investigation.
- Return-to-work restrictions and occupational health notes with highly restricted access.
- PPE/safety training and certification tracking.
- Emergency contacts and evacuation/incident roster exports.
- Wellbeing resources without storing unnecessary sensitive health details.

5.16 Assets, Access & Facilities

- Asset inventory: laptop, phone, SIM, access card, vehicle, equipment, uniform/PPE and custom types.
- Issue/return/transfer, serial number, condition, value, owner, acknowledgment and photo/document evidence.
- Automated onboarding/offboarding tasks for access and asset handover.
- Optional integration with identity/device systems later; do not make HR the technical source of truth for device telemetry.

5.17 Analytics, Reports & Executive Intelligence

- Role-specific dashboards with configurable widgets and saved filters.
- Standard reports: headcount, hires/exits, turnover, absence, attendance, overtime, payroll cost, compensation distribution, recruitment funnel, performance, learning, documents expiring, demographics where lawful.
- As-of-date reports and historical trend reports using effective-dated data.
- Report builder: selectable fields, filters, grouping, calculated columns, saved templates, scheduled delivery and export permission.
- Executive metrics: headcount plan vs actual, payroll cost, regrettable attrition, time-to-fill, span of control, internal mobility, performance distribution, training compliance.
- Data-quality dashboard: missing fields, duplicates, expired docs, invalid manager chains, orphan positions and failed integrations.

5.18 Automation, Workflow & Notifications

- Reusable workflow builder with trigger, conditions, steps, approver resolution, SLA, escalation, reminders, delegation and completion actions.
- Triggers from hire, date reached, field changed, document expiring, request submitted, probation ending, salary changed, termination scheduled and webhook/API event.
- Actions: create task, request approval, send email/in-app notification, generate document, update field, call integration, add learning, assign asset task, create case.
- Notification preferences and digesting; avoid flooding employees with one email per minor event.
- Workflow run log showing each step, rule outcome, timestamps, actor and failure/retry.

5.19 AI Assistant / Agent Layer

- Natural-language HR search: "Who has a visa expiring in 60 days?" with permission-aware structured query generation.
- Summarize employee history, review feedback, HR cases or payroll exceptions only for users already authorized to see the source records.
- Draft letters, job descriptions, appraisal comments, interview questions and policy communications using templates and human approval.
- Data quality assistant: flag missing/contradictory records and propose fixes; never silently alter sensitive data.
- Manager nudges: overdue reviews, leave conflicts, unapproved time, probation deadlines and development follow-ups.
- Analytics explanations: describe changes in attrition/headcount/cost but show the underlying filter and numbers.
- AI actions should call the same audited service layer as humans, with explicit scopes, confirmation for high-impact changes and complete trace logs.

6. Employee Lifecycle State Model

Stage	Worker status examples	Key automated events
Candidate	prospect, applicant, interviewing, offer	Consent, interview tasks, offer approval, background/pre-employment checks.
Pre-hire	accepted, preboarding	Create worker shell; collect docs/bank; assign onboarding tasks; create future position assignment.
Active	probation, confirmed, active, on leave	Time/leave/payroll/performance/learning; document expiry; salary/role changes.
Temporary status	suspended, secondment, long leave	Access/benefit/pay rules by policy; preserve employee relationship.
Notice period	resigned, termination pending, retirement pending	Offboarding tasks, final leave balance, asset/access checklist, final settlement draft.
Terminated	resigned, dismissed, end contract, retired	Disable login at effective time, final docs, archive; keep history and rehire eligibility.
Rehired	new employment instance	New employment/position/compensation record linked to same person; do not duplicate identity history.

Data modeling rule Separate PERSON from EMPLOYMENT. One person may have multiple employment relationships over time. This avoids duplicate people when someone is rehired or changes legal entity.

7. Data Model Blueprint and MySQL Type Conventions

Do not build a single giant employees table. Use domain tables with references, effective dates and history.

7.1 Type conventions

Data kind	Recommended MySQL type	Rule
Internal primary key	BIGINT UNSIGNED	Auto-increment is simple and efficient for internal joins.
Public/API identifier	CHAR(36) UUID or BINARY(16)	Do not expose sequential IDs in public URLs/APIs.
Tenant/company scope	BIGINT UNSIGNED tenant_id	Include on business tables now if productization/multi-company is possible.
Short code	VARCHAR(20-50)	Employee no., cost center, leave code; unique within appropriate scope.
Names/titles	VARCHAR(120-200)	Use utf8mb4; do not assume Western naming structure.
Email	VARCHAR(254)	Normalize for comparison; preserve original casing if desired.
Phone	VARCHAR(32)	Store E.164-normalized value + display/original if needed.
Money	DECIMAL(19,4)	Never FLOAT/DOUBLE for salary/payroll. Store currency_code CHAR(3).
Percent/rate	DECIMAL(9,4)	Keep precision explicit.
Date only	DATE	DOB, start date, entitlement date, expiry date.
Timestamp	DATETIME(6)	Store UTC; convert using user/company timezone.
Boolean	BOOLEAN / TINYINT(1)	Use clear names such as is_active, requires_attachment.
Status/category	Lookup FK / VARCHAR code	Avoid MySQL ENUM for business values that HR will later change.
Free text	TEXT	Comments, reasons; define max length in application.
Structured flexibility	JSON	Only for dynamic form answers/metadata; do not hide core searchable fields in JSON.
Files	Metadata row + private object path	Store file bytes outside DB unless there is a specific reason.
Version/hash	INT + CHAR(64)	Document/payslip template version and SHA-256 for integrity where useful.

7.2 Foundational table catalogue

Table / Entity	Purpose
tenants	Organization/customer boundary; settings, locale, timezone, feature flags.
legal_entities	Registered employing entities; country, registration, payroll identity.
business_units	Optional strategic divisions.
locations	Branches/sites; address, timezone, geo metadata, calendar.
departments	Department hierarchy and owners.
teams	Operational teams below departments.
cost_centers	Finance mapping.
job_families	Job architecture grouping.

job_titles	Standard titles.
grades	Level/grade, salary band references.
positions	Approved seat/headcount; reports_to_position_id, status, FTE, budget.
persons	Human identity independent of employment.
person_contacts	Email/phone/address records with type and validity.
emergency_contacts	Emergency contacts.
dependents	Dependents/benefit relations.
employments	Employment relationship, legal entity, worker type, dates/status.
employee_assignments	Effective-dated position/department/location/manager/FTE assignment.
contracts	Contract versions, work pattern, term, probation/notice.
employee_identifiers	Passport, Emirates ID, national ID, work permit - encrypted/masked metadata.
employee_bank_accounts	Encrypted bank data, payroll flags, verification state.
custom_field_definitions	Admin-created field definitions and visibility.
custom_field_values	Typed or JSON-backed configurable values.
employee_events	Human-readable lifecycle timeline/event references.
audit_events	Security/business audit events, actor, object, action, old/new references.
users	Login identity and account status.
roles	Role definitions.
permissions	Atomic permission codes.
user_role_scopes	Role + legal entity/location/department/hierarchy scope.
delegations	Temporary approval/access delegation with start/end.

7.3 Operational domain table catalogue

Table / Entity	Purpose
leave_types	Policy type metadata.
leave_policies	Eligibility/accrual/carry-forward rule set with effective dates.
leave_policy_assignments	Which population gets which policy.
leave_requests	Request header/status/approvals.
leave_request_days	Daily/hourly breakdown when needed.
leave_ledger	Immutable balance transactions.
holiday_calendars	Country/location calendars.
shifts	Shift templates.
rosters	Employee schedule assignment.
time_punches	Clock events/imports.
attendance_days	Calculated daily attendance result/version.
timesheets	Period/project time.
overtime_requests	Preapproval/actual OT.
salary_structures	Salary package definition/version.
compensation_assignments	Employee pay components effective-dated.
salary_change_requests	Controlled salary change workflow.
payroll_periods	Payroll calendar/cutoff/status.
payroll_runs	Run/version/lock.

payroll_run_employees	Employee-level payroll results.
payroll_result_lines	Earning/deduction component results.
payslips	Generated document reference/version/status.
payroll_adjustments	Retro/one-off input with source/approval.
loans	Loan/advance contract.
loan_installments	Scheduled/paid deductions.
expense_claims	Claims/reimbursements.
expense_items	Line-item receipt/category/amount.
benefit_plans	Benefit definition.
benefit_enrollments	Employee/dependent enrollment.
employee_documents	Private document metadata/version/expiry.
document_templates	Letter/PDF template with placeholders.
generated_documents	Issued document with ref/version/hash/approvals.
request_types	Configurable Other Request/HR service catalogue.
requests	Generic service request header.
request_fields	Dynamic request answer values.
request_comments	Employee-visible/internal comments.
approval_instances	Workflow approval runtime.
approval_steps	Resolved approvers/status/timestamps.
workflow_definitions	Reusable workflow/version.
workflow_runs	Runtime execution state.
workflow_tasks	Human/system tasks.
notifications	In-app/email notification records.
notification_preferences	User preference/digest settings.

7.4 Talent, recruitment and planning tables

Table / Entity	Purpose
headcount_plans	Period/entity/department planned FTE and budget.
requisitions	Approved hiring request linked to position.
job_postings	Published vacancy channels/locale.
candidates	Candidate identity and consent.
applications	Candidate-to-requisition record.
application_stage_history	Pipeline transitions.
interviews	Interview schedule/panel.
interview_scorecards	Structured feedback.
offers	Offer versions/approval/signing.
onboarding_templates	Journey template.
onboarding_instances	Employee-specific journey.
onboarding_tasks	Task owner/due/completion.
performance_cycles	Cycle configuration/population.
performance_reviews	Employee review instance.
review_sections	Section results.
review_responses	Question/rating/comments.

goals	Individual/team/company goals.
goal_updates	Progress history/evidence.
feedback	Continuous feedback records.
one_on_ones	1:1 agenda, notes, actions.
calibration_sessions	Calibration setup.
calibration_entries	Ratings/talent box outcome.
pips	Performance improvement plans.
pip_milestones	PIP actions/reviews.
succession_roles	Critical role/position planning.
succession_candidates	Successor readiness/risk.
skills	Skill taxonomy.
employee_skills	Proficiency/evidence.
courses	Learning catalog.
course_sessions	Scheduled delivery.
enrollments	Enrollment/completion.
certifications	Certification definitions.
employee_certifications	Issue/expiry/status.
surveys	Survey setup.
survey_responses	Responses with anonymity controls.
recognitions	Kudos/recognition.
assets	Asset inventory.
asset_assignments	Issue/return history.
hr_cases	Confidential/general HR case.
case_events	Case timeline.
disciplinary_actions	Outcome/warning records.
health_safety_incidents	Incident records with restricted access.

8. Employee Data Dictionary - What to Capture

Not every field should be mandatory. Group fields by sensitivity, country and lifecycle stage.

Group	Field example	Type	Notes
Identity	employee_no	VARCHAR(30)	Unique in tenant/legal entity policy; immutable after issue unless correction workflow.
Identity	legal_first_name / legal_last_name	VARCHAR(120)	Support alternate/middle names and cultures with different naming patterns.
Identity	preferred_name	VARCHAR(120)	Used in UI/communications.
Identity	date_of_birth	DATE	Restricted; only if business/legal need.
Identity	nationality_country_code	CHAR(2)	ISO country code.
Contact	work_email / personal_email	VARCHAR(254)	Personal email restricted; work email may be directory-visible.
Contact	mobile_phone	VARCHAR(32)	Normalized E.164.
Contact	address fields	VARCHAR/TEXT	Country-aware; restricted.
Employment	employment_type_code	FK/code	employee, contractor, intern etc.

Employment	work_pattern_code	FK/code	full-time, part-time, temporary, flexible, remote, job-share.
Employment	start_date / end_date	DATE	End nullable; use lifecycle workflow.
Employment	probation_end_date	DATE	May be derived but store confirmed effective date.
Employment	notice_period_days	SMALLINT	Policy/contract; nullable.
Organization	legal_entity_id	BIGINT FK	Employer.
Organization	position_id / department_id / location_id	BIGINT FK	Use effective-dated assignment table.
Organization	manager_person/employment_id	BIGINT FK	Prefer reporting via position if position management is enabled.
Compensation	currency_code	CHAR(3)	ISO 4217.
Compensation	basic_salary	DECIMAL(19,4)	Keep in compensation components, not employee master.
Compensation	pay_frequency	FK/code	monthly, biweekly, weekly etc.
Compliance	passport_no	Encrypted VARCHAR	Masked by default; store country, issue/expiry separately.
Compliance	visa / Emirates ID / work permit	Encrypted + DATE	Document identifiers + validity; role-restricted.
Bank	IBAN/account/routing	Encrypted VARCHAR	View masked; full value only to payroll-authorized users.
Performance	grade / level	FK	Effective-dated with assignment or compensation.
Skills	skills/certifications	Many-to-many	Never comma-separated strings.
System	status	FK/code	Use lifecycle state; login status is separate.
System	created_at / updated_at	DATETIME(6)	UTC.
System	created_by / updated_by	BIGINT FK	Useful but not a substitute for detailed audit events.

Avoid this anti-pattern Do not store "annual_leave_balance", "salary", "manager_name", "department_name" as copied mutable fields on the employee row. Use ledgers/assignments/references and calculate the current view.

9. Workflow and Approval Engine Specification

Component	Capabilities
Trigger	Manual submission; object created/changed; effective date reached; scheduled rule; document expiry; webhook/API; import completion.
Conditions	Field comparisons; role; legal entity; department; amount; leave type; days; salary %; tenure; country; grade; request answers.
Approver resolution	Named user, direct manager, manager-of-manager, department head, HR role in scope, payroll role, finance role, position incumbent, dynamic query.
Step types	Approval, acknowledgment, task, document generation, notification, data update, integration call, wait-until-date, branch/condition.
Modes	Sequential, parallel all, parallel any/threshold, FYI-only.
SLA	Due date, reminders, escalation, auto-reassign, skip if approver equals requester, out-of-office delegation.
Controls	No self-approval for configured sensitive actions; maker-checker for

	payroll/salary/termination; prevent duplicate active workflows.
Audit	Workflow version, conditions evaluated, approver resolved, action, comment, timestamp, IP/device where appropriate, failure/retry.
Change management	Version workflow definitions. Existing in-flight requests continue on their original version unless explicitly migrated.

10. Official HR Documents and PDF Outputs

Document catalogue to support

Category	Documents
Employment	Offer letter; employment contract; contract amendment; probation confirmation/extension; promotion; transfer; salary revision; designation change.
Employee requests	Salary certificate; salary transfer letter; NOC; employment certificate; leave confirmation; bank/embassy letter; travel letter.
Payroll	Payslip; annual pay summary; bonus letter; loan statement; final settlement; gratuity/end-of-service statement.
Performance	Review summary; PIP plan; goal plan; promotion recommendation/decision; development plan.
Conduct	Warning letters; investigation invite; disciplinary outcome; appeal outcome - restricted.
Exit	Resignation acceptance; termination letter; clearance; experience/service letter; final dues acknowledgement; asset return confirmation.
Compliance	Policy acknowledgements; confidentiality/IP forms; document expiry notices; training certificates.

Document engine requirements

- Template versioning: changing a template must not alter already-issued PDFs.
- Field placeholders from approved data only; conditional sections by legal entity/country/employment type.
- Unique reference number pattern per document type/entity/year.
- Preview → approval (if required) → generate → sign/issue → employee acknowledgement/download.
- Private storage; authorization is rechecked on every download.
- Store PDF generation status: pending, generated, generation_failed, superseded, voided.
- Store template version, issuer, approver, generated_at, SHA-256 and source object reference when appropriate.
- Support English first; make templates localization-ready for Arabic and other languages without rewriting backend logic.

11. Payroll and Compensation Engine - Detailed Design

Scope choice A world-class HCM can either calculate statutory payroll itself or orchestrate/export to a local payroll provider. For your system, build a strong payroll core with pluggable country rules. Do not hard-code one country's calculations into generic payroll tables.

Payroll component model

Component type	Examples	Configuration
Base pay	Basic salary, hourly base	Fixed amount/rate; FTE; effective dates.
Fixed earnings	Housing, transport, phone, role allowance	Amount/percentage; taxable/WPS treatment by country adapter.
Variable earnings	Overtime, commission, bonus, incentive	Input source, approval, formula, period.
Reimbursements	Travel, fuel, mobile, business expense	Usually non-earning; policy and finance mapping.
Deductions	Unpaid leave, loan, advance, penalties where lawful, other deductions	Order/limits/consent/legal rules.
Employer contributions	Pension/insurance/other statutory	Country-specific.
Final settlement items	Leave encashment, gratuity/EOS, notice pay/recovery, final salary	Termination-aware, separately reviewable.

Payroll run controls

1. Open payroll period and snapshot eligible active/terminated employees in the payroll group.
2. Import/collect approved variable inputs (attendance, overtime, leave, loans, reimbursements, bonus).
3. Calculate draft results and run validation rules: missing bank, negative net pay, unusual variance, missing salary structure, overlapping comp rows.
4. Payroll admin resolves exceptions; every manual override requires reason and audit.
5. Maker submits run; checker/authorized approver reviews summary, variance and exception reports.
6. Lock the approved run. Locked result lines are immutable; corrections use an adjustment/reversal or a new version.
7. Generate bank/WPS/provider output and mark payment transmission status.
8. Publish employee payslips only after authorized release; keep version history.
9. Export accounting journal/reconciliation and close period.

12. Performance and Appraisal Design

Capability	Minimum professional implementation	Advanced implementation
Goals	Weighted goals, target/date, progress, comments, evidence.	Cascading OKRs, shared goals, metric feeds, goal library.
Reviews	Self + manager review, configurable questions/scales, sign-off.	360 feedback, project reviews, probation cycles, review automation.
Competencies	Role/grade competency library and ratings.	Skill inference, proficiency evidence, role gap analysis.
1:1s	Agenda, notes, action items, recurring cadence.	Suggested topics from goals/feedback/tasks; private vs shared sections.
Feedback	Give/request feedback with visibility setting.	Continuous feedback nudges, recognition link, structured tags.
Calibration	HR adjusts/reviews ratings with comments/audit.	9-box grid, distribution analysis, compensation linkage.
PIP	Plan, objectives, milestones, check-ins, outcome.	Templates, HR/legal approvals, automatic reminders and evidence pack.
Succession	Critical roles and named successors.	Readiness, risk of loss, talent pools, development actions.

13. UAE Country Pack - Configuration Requirements

This is a system-design checklist, not legal advice. Labour/payroll rules change; store policy versions and have HR/legal validate production settings.

Area	UAE-ready capability
Employment	Fixed-term contract metadata and work patterns including full-time, part-time, temporary, flexible, remote and job-sharing where applicable.
Working time	Configurable normal hours, overtime rules, rest days, public holidays, seasonal/Ramadan schedules and exceptions.
Leave	Policy engine capable of annual leave accrual/proration and country-specific leave types; never hard-code entitlement into routes.
Payroll / WPS	Payroll group/entity identifiers, WPS-oriented salary output/export fields, due-date/reconciliation status and evidence of payment.
Identity/immigration	Passport, visa/residency, Emirates ID, work permit, labor-related reference numbers, issue/expiry dates and reminders.
End of service	Configurable gratuity/final settlement engine with effective-dated legal/policy formula and itemized calculation evidence.
Insurance / protection	Track medical insurance and other company/legal coverage, policy/member number, effective/expiry dates.
Emiratisation optional pack	Nationality/Emirati status, job skill level, entity population and reporting fields only where the organization requires them.
Privacy	Data inventory, purpose/access controls, retention, correction/export/processing rights support and cross-border transfer governance to help organizations comply with UAE PDPL obligations.
Templates	Arabic/English-ready official letters and company-specific legal entity letterheads.

Why this matters UAE official sources confirm that private-sector employment rules cover contracts, working hours/overtime, leave, employee records, termination/end-of-service and other areas; WPS is an electronic wages transfer system used to oversee timely salary payment. The data model therefore needs to support these as first-class concepts, not afterthoughts.

14. UX/UI Design System - Exact Recommendation

The visual goal: premium modern SaaS, calm and data-dense when necessary, without looking like a generic admin template.

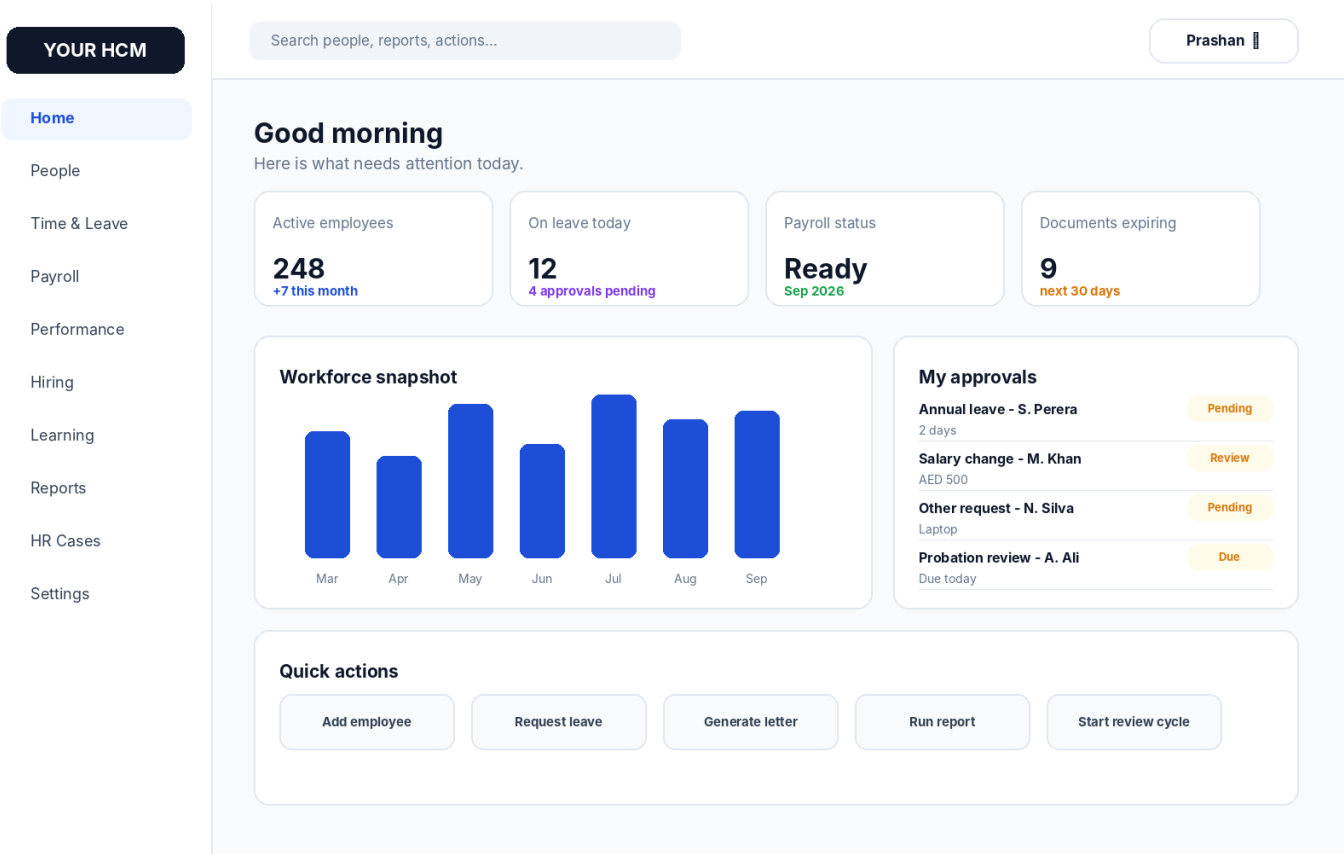


Figure 2 - Suggested role-based dashboard direction.

14.1 Design tokens

Token	Recommended value	Usage
Font family	Inter, system-ui, -apple-system, Segoe UI, sans-serif	Use one UI family across the app; strong readability in tables/forms.
Base body	14px / 1.45	Default desktop application text.
Small/meta	12-13px / 1.4	Table metadata, captions, helper text; avoid <12px.
Page title	28-32px / 1.2, 650-700 weight	Only one main page title.
Section title	18-20px / 1.3, 650	Card/section headers.
Navigation	14px, 550-600	Consistent labels.
Spacing	4, 8, 12, 16, 24, 32, 40, 48 px	8px base rhythm with 4px for fine adjustments.
Control height	40px default; 44px touch-friendly	Inputs/buttons; compact 36px only for dense admin tables.
Border radius	10-12px cards/inputs; 999px chips	Avoid excessive pill-shaped everything.
Border	1px #E2E8F0	Prefer border + subtle surface over heavy shadows.
Shadow	0 1px 2px rgba(15,23,42,.05); overlay stronger	Use sparingly.
Content width	Max ~1440px; 24-32px page padding desktop	Tables can use full width.
Sidebar	240-256px expanded; 72px collapsed	Persistent desktop; drawer on mobile.

Top bar	64px	Global search, tasks/notifications, user menu.
Table row	48-52px default	Use 56px if row contains secondary metadata.

14.2 Color system

Role	Color	Use
App background	#F8F AFC	Main page canvas.
Surface/card	#FFFFFF	Cards, panels, forms.
Primary text	#0F172A	Headings and important text.
Secondary text	#64748B	Metadata/helper text.
Primary action	#1D4ED8	Buttons, active nav, links.
Primary soft	#EFF6FF	Selected states, light info background.
Success	#16A34A	Approved/active/completed.
Warning	#D97706	Pending/due/attention.
Danger	#DC2626	Rejected/error/termination/destructive action.
Purple accent	#7C3AED	Talent/performance optional accent.
Border	#E2E8F0	Separators, input borders.
Sidebar option	#FFFFFF or #0F172A	Prefer light default for calm enterprise UI; dark sidebar is optional branding variant.

Accessibility baseline WCAG 2.2 AA requires at least 4.5:1 contrast for normal text and 3:1 for large text. Do not use pale gray text as decorative “minimalism” when the content is operationally important.

14.3 Component behavior

- Buttons: one strong primary action per view; secondary outlined/neutral; destructive actions red and separated from routine actions.
- Forms: labels above inputs; show required status clearly; use field groups and progressive disclosure; do not place 40 fields on one page.
- Tables: sticky header when long; column chooser; filters in a clear filter bar; saved views; bulk selection; server-side pagination; export permission separate from view permission.
- Status chips: short semantic text (“Pending”, “Approved”, “Rejected”, “Draft”, “Locked”); color supports meaning but never carries meaning alone.
- Drawers: use right-side drawers for quick profile/request preview without losing table context.
- Modals: only for focused confirmation or very small forms. Full workflows deserve pages/drawers.
- Timeline: every employee/request/payroll object should show meaningful history with actor/date/action.
- Empty states: explain what the module is for and provide the next action; avoid blank cards.
- Error handling: show field-level errors plus a top summary for long forms; preserve entered values.
- Loading: skeletons for cards/tables; disable duplicate submissions; optimistic UI only for low-risk reversible actions.
- Responsive: bottom/compact navigation for common employee flows on mobile; wide payroll/reports may use horizontally scrollable tables with fixed key columns.

[← People / Employee profile](#)

AK

Aisha Khan
 Senior Finance Executive • Finance • Dubai
ACTIVE

Actions

Employee ID: UAE-00248

Overview

Employment

Compensation

Time & Leave

Performance

Documents

History

Employment summary

Manager	Work location
Omar Rahman	Dubai - HQ
Employment type	Start date
Full-time	14 Feb 2022
Grade	Cost center
GS	FIN-01

Current status

Leave balance	Next review
18.5 days	20 Oct 2026
Visa expiry	Last salary change
12 Jan 2027	01 Jul 2026
Assets	Open HR cases
2 assigned	0

Timeline

- 09 Sep 2026 **Salary certificate generated** HR Admin
- 05 Sep 2026 **Annual leave approved: 2 days** Manager
- 01 Jul 2026 **Salary revised to AED 9,500** HR + Payroll
- 14 Feb 2026 **Performance review completed: 4.2/5** Manager

Figure 3 - Employee profile direction: context + tabs + role-filtered fields + timeline.

14.4 Navigation information architecture

Primary nav	Subareas
Home	Dashboard, inbox/tasks, quick actions, announcements.
People	Employee directory, org chart, positions, lifecycle actions, documents.
Time & Leave	Leave, attendance, shifts/rosters, timesheets, overtime, calendars.
Payroll & Rewards	Payroll runs, compensation, salary changes, loans, expenses, benefits, payslips.
Talent	Performance, goals, feedback, 1:1s, calibration, succession, learning, skills, surveys.
Hiring	Headcount plan, requisitions, jobs, candidates, interviews, offers, onboarding.
HR Services	Requests, cases, grievance/disciplinary, knowledge base.
Reports	Dashboards, standard reports, report builder, scheduled reports, data quality.
Administration	Company/org, master data, policies, workflows, templates, roles/permissions, integrations, audit, feature settings.

15. Technical Architecture for Python / MySQL / HTML / CSS / JS

Recommended Technical Architecture

Keep the existing Python stack, but separate concerns so the platform can scale without a rewrite.

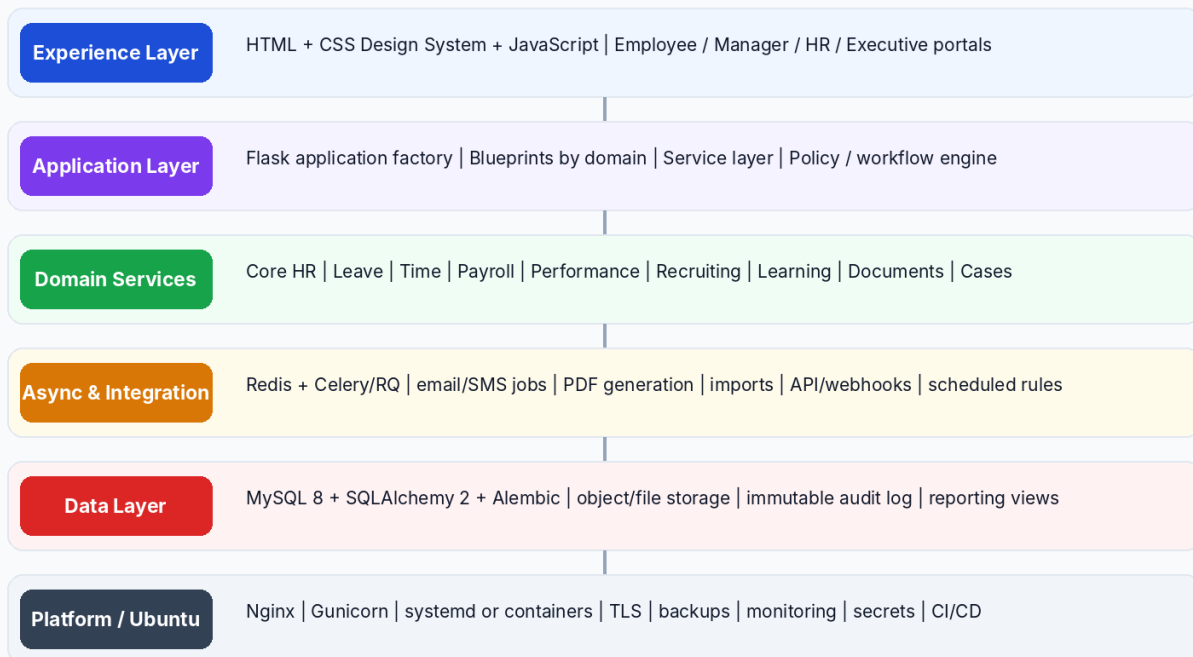


Figure 4 - Recommended modular-monolith architecture.

15.1 Backend organization

Layer	Recommendation
Flask app	Application factory; environment config; Blueprints by domain (people, leave, time, payroll, talent, recruiting, docs, reports, admin).
Routes/controllers	HTTP validation, permission call, service call, response/redirect. Keep business rules out of route functions.
Services	Transaction boundaries and domain operations: <code>approve_leave()</code> , <code>schedule_transfer()</code> , <code>close_payroll()</code> , <code>issue_document()</code> .
Policies	Central authorization functions/objects so view/export/update decisions are consistent.
Models	SQLAlchemy 2 declarative models; relationships; constraints; indexes.
Migrations	Alembic only; additive/backward-compatible migrations first; no destructive reset as a normal deployment step.
Background jobs	Redis + Celery or RQ for PDF generation, email, imports, scheduled expiries, report exports and integration retries.
API	Versioned <code>/api/v1</code> ; service account auth; same policy/service layer as UI.
Events	Internal domain-event table/dispatcher for <code>employee_hired</code> , <code>salary_changed</code> , <code>termination_scheduled</code> , <code>document_expiring</code> etc.
Files	Private filesystem/object storage abstraction; metadata DB; antivirus/validation hook; authorized download endpoint.

15.2 Frontend approach

- Keep server-rendered Jinja if it is already working; it is perfectly capable of a premium interface.
- Build a reusable component CSS layer: buttons, inputs, select, table, card, tabs, chips, drawer, modal, toast, timeline, avatar, empty state, skeleton, pagination.
- Use CSS custom properties for colors, spacing, radius, typography and shadows so branding changes do not require page-by-page edits.
- Use modular JavaScript for filters, drawers, dependent selects, autosave drafts, table actions and accessible dialogs. Avoid one giant app.js.
- Use fetch() for partial actions/APIs where it improves UX; server still remains authoritative.
- Do not introduce a SPA framework merely to look modern. Add one only if interaction complexity later justifies it.

16. Security, Privacy and Audit Controls

Security target Treat this as an application containing sensitive personal and payroll data. OWASP ASVS Level 2 is a sensible verification target for most deployments handling this kind of data, plus stronger controls for payroll/identity exports.

Control area	Required controls
Authentication	MFA for HR/payroll/admin; strong password hashing (Argon2id preferred or well-configured bcrypt); password reset tokens with short expiry; login throttling; optional SSO OIDC/SAML.
Sessions	Secure/HttpOnly/SameSite cookies, CSRF protection, server-side session revocation, inactivity/absolute timeout, logout-all-sessions.
Authorization	Deny by default; RBAC + scope + data sensitivity; check every server-side action and file download; separate export/bulk/download permissions.
Sensitive fields	Encrypt bank/national IDs/passport values at application layer where appropriate; mask by default; log access to full values.
Documents	Allowed file types, extension + MIME validation, size limits, malware scanning hook, private storage, random object keys, no user-supplied paths.
Audit	Append-only business/security audit; salary/payroll/role/download/export/impersonation events; old/new values or safe diffs; timestamp/actor/object/reason.
Logging	Structured logs; correlation/request ID; never log passwords, full tokens, bank details or sensitive document contents.
Web security	CSP, HSTS, TLS, X-Content-Type-Options, frame protection, secure referrer policy, output escaping, input validation, parameterized SQL via ORM.
Rate limits	Login/reset/OTP, exports, expensive reports, file uploads and public candidate endpoints.
Secrets	Environment/secret store; no credentials in Git; rotate DB/mail/API secrets.
Backups	Encrypted, automated, off-host copy, tested restore; MySQL binlog/PITR if needed.
Privacy	Purpose/retention metadata; access/correction processes; configurable retention/erasure/anonymization where legally permitted; export tracking.
Admin safety	Break-glass super-admin; impersonation banner; reason required; session recorded in audit; destructive configuration guarded.

Security limits by data class

Class	Examples	Default visibility
-------	----------	--------------------

Directory	Name, job title, department, work email	Employees in company or configured directory scope.
Internal HR	Employment dates, manager, grade, leave status	Self + manager subset + HR.
Confidential	Salary, performance, candidate assessments, personal address	Self/authorized manager subset/HR/payroll as configured.
Highly restricted	Bank, national IDs/passport numbers, medical evidence, grievance/disciplinary investigation	Named functional roles only; masked; download/access audited.
Aggregate only	Anonymous survey, sensitive diversity metrics	Only aggregated above minimum threshold.

17. Reporting, Metrics and Dashboard Catalogue

Domain	Core metrics
Workforce	Headcount, active FTE, joiners, leavers, turnover, regrettable attrition, tenure, span of control, vacancies, position fill rate.
Leave/absence	Leave balance liability, absence rate, leave by type, approval SLA, overlapping leave, negative/excess balances.
Attendance	Late rate, absence, missing punches, overtime hours/cost, roster coverage, timesheet completion.
Payroll	Gross/net payroll, total employment cost, payroll variance, salary distribution, compa-ratio, overtime cost, unpaid leave deductions, exception counts.
Recruiting	Open requisitions, aging, time-to-fill, time-to-hire, source conversion, interview-to-offer, offer acceptance, recruiter workload.
Onboarding	Task completion, preboarding completion, time-to-productivity proxy, probation due/confirmed/extended.
Performance	Cycle completion, rating distribution, goal completion, high performer, PIP, calibration movement, promotion readiness.
Learning	Mandatory compliance %, course completion, certification expiry, training hours/cost, skill gaps.
Documents/compliance	Expiring visas/IDs/contracts/insurance/certifications, missing mandatory documents, policy acknowledgements.
HR Services	Open cases, SLA breach, request volume by category, resolution time, reopen rate, confidential case counts only for authorized roles.
Diversity/DEI where lawful	Demographic distributions and outcomes only where collection/processing is lawful and privacy thresholds are applied.
Data quality	Missing manager, invalid hierarchy, duplicate identifiers, missing bank data, overlapping assignments/compensation, orphan records, failed integrations.

18. AI and Codex Strategy

18.1 In-product AI guardrails

- AI reads through a permission-aware retrieval layer. It must never bypass the application's RBAC/scope checks.
- AI may draft and recommend; deterministic code calculates payroll, leave balances, entitlements and final legal outputs.
- High-impact writes require explicit confirmation and normal approval workflows.
- Every AI-triggered action logs the user, prompt intent (not necessarily full sensitive prompt), tool/action, object changed and result.
- Use structured tool/function calls to domain services instead of allowing the model to generate arbitrary SQL.
- Provide citations/links back to source records in AI answers whenever possible.

18.2 Codex development protocol

Step	Codex instruction pattern
1. Inspect first	Read current structure, dependencies, models, migrations, templates and tests. Report findings before architectural change.
2. Preserve stack	Extend the existing Flask/SQLAlchemy/MySQL/HTML/CSS/JS system. Do not replace frameworks or redesign unrelated pages without explicit reason.
3. Migration safety	Use Alembic additive migrations, backfill scripts and rollback plan. Never drop/reset production data as a convenience.
4. Small vertical slices	Implement schema + service + permission + route + UI + audit + tests for one feature end-to-end.
5. Tests first for rules	Unit-test leave accrual, payroll formulas, approval resolution, permissions and effective dating.
6. UI quality gate	Responsive, keyboard accessible, no generic Bootstrap defaults, consistent design tokens/components.
7. Security review	Check authz on every endpoint/file, CSRF, upload validation, secrets, logs, export/download permissions.
8. Final verification	Run migrations on a copy/staging DB, full tests, smoke workflows, PDF generation, backup/restore check and visual QA.

18.3 Reusable master prompt for Codex

You are upgrading an existing production HR application. Do not rebuild it or replace the stack unless a concrete blocking reason is proven. First inspect the repository, database models, migrations, routes, templates, CSS/JS, permissions and tests. The target is a premium modern HCM product using Python/Flask, SQLAlchemy/Alembic, MySQL, HTML/CSS/JavaScript and Ubuntu. Preserve existing data and behavior unless the requirement explicitly changes it. Use additive migrations, service-layer business logic, centralized permissions, immutable audit for sensitive changes, private files, responsive WCAG-aware UI and automated tests. Before coding, state the implementation plan and affected files. After coding, run tests and explain migration/deployment steps. Never use destructive database reset/drop operations without explicit approval.

19. Non-Functional Requirements and System Limits

Area	Target / requirement
Performance	Common dashboard/profile/list pages p95 under ~2 seconds on normal business loads; API list endpoints paginated; background jobs for large exports/PDF batches.
Scale	Design tables/indexes for at least tens of thousands of workers per tenant without changing core model; test larger if product target requires it.
Availability	Practical internal target 99.9% with monitored service and maintenance process; define higher SLA only if operations can support it.
Backups	Daily full + frequent incremental/binlog strategy; encrypted off-host copy; quarterly restore drill minimum.
RPO/RTO	Define by business. A strong SME baseline: RPO <= 15-60 minutes for DB with binlogs and RTO <= 2-4 hours; validate cost/need.
Browser	Current Chrome/Edge/Firefox/Safari; responsive employee workflows.
Accessibility	WCAG 2.2 AA target; keyboard, focus, labels, contrast, 200% zoom, error identification.
Localization	Timezone, locale/date/number formats, currency, country codes and translatable UI strings.
Data retention	Configurable by document/case/data class and jurisdiction; legal hold support for records that cannot be deleted.
Audit retention	Longer than normal application logs; protected from routine modification/deletion.

Exports	Async for large exports, watermark/reference if sensitive, permission and audit, row/field scope identical to on-screen access.
Attachments	Configurable size/type; private; scan hook; quota and retention controls.
AI	No unrestricted SQL/file-system access; permission-aware tools; human confirmation for high-impact actions.

20. Recommended Implementation Roadmap

Because an HR app already exists, use an upgrade roadmap. Do not pause operations for a “big bang” rewrite.

Phase	Indicative time	Scope	Why
Phase 0 - Architecture & data safety	1-2 weeks	Repository/DB audit; MySQL schema review; app factory/blueprint/service boundaries; Alembic discipline; role/permission foundation; audit log; design tokens/component cleanup; test harness; staging + backup/restore.	This removes structural debt before adding more modules.
Phase 1 - Core HCM foundation	2-4 weeks	Organization/legal entities/locations/departments/positions; employee master; effective-dated assignments; manager hierarchy; directory/org chart; secure documents; lifecycle timeline; employee/manager self-service shell.	Creates the source of truth every later module needs.
Phase 2 - Requests, Leave, Time & Documents	3-5 weeks	Convert Other Requests into service catalogue; workflow engine; leave ledger/policies/cancellation; attendance/shift foundation; official document templates; salary certificate/leave confirmations; notifications/task inbox.	High daily HR value and cleans existing modules.
Phase 3 - Payroll & Rewards	4-8 weeks	Salary structures/history, compensation workflow, payroll periods/runs/results, variable inputs, payslips, loans/expenses, final settlement, UAE WPS adapter, finance exports/reconciliation.	Highest-risk module; requires strong tests and maker-checker.
Phase 4 - Performance & Talent	4-7 weeks	Goals, appraisals, 1:1s, feedback, competencies, calibration, PIP, succession, learning/certifications, surveys.	Turns HRIS into HCM.
Phase 5 - Recruiting & Workforce Planning	4-7 weeks	Headcount plan/positions, requisitions, ATS, interviews, offers, onboarding journeys, recruiting analytics.	Closes hire-to-retain lifecycle.
Phase 6 - Advanced Analytics, AI & Integrations	ongoing	Report builder, scheduled reporting, data quality, AI assistant with tools/guardrails, SSO, APIs/webhooks, biometric/payroll/bank/provider integrations, PWA/mobile enhancements.	Differentiation and scale after data/process foundation is stable.

Do not treat the estimates as a promise Actual duration depends on the current code quality, data migration complexity, payroll country scope, test coverage and number of people developing. Use them as sequencing, not a contractual timeline.

21. Release Gates - What Must Be True Before Calling It “Professional”

#	Release gate
1	Every sensitive action has a defined permission and audit event.
2	Every request/approval shows current status, approver, history and SLA/due information.
3	Employee lifecycle changes are effective-dated and do not overwrite historical truth.
4	Leave balances come from a ledger or reproducible transactions, not manual mutable totals alone.
5	Salary changes have history, approval, reason and effective date.
6	Payroll run can be reproduced/explained; locked payroll cannot be silently edited.
7	Documents are private, versioned and re-authorized on download.
8	Employee termination disables access at the correct effective time but preserves history.
9	Manager views cannot expose bank, full IDs, medical or unrelated salary information.
10	Reports respect the same field/scope permissions as screens.
11	Bulk export and document download are separately permissioned and audited.
12	All lists have search/filter/sort/pagination and usable empty/loading/error states.
13	All primary employee actions work on mobile-sized screens.
14	UI keyboard navigation, focus visibility and contrast meet the accessibility baseline.
15	MySQL migrations can run forward safely on staging copy; no reset/drop requirement.
16	Automated tests cover leave, payroll, permissions, workflow and key lifecycle rules.
17	Backups restore successfully; deployment rollback procedure is documented.
18	UAE rules are stored as configurable/effective-dated policy, not assumed permanent constants.
19	AI cannot see or change records outside the user's ordinary permissions.
20	HR can configure master data, policies, workflows and templates without requiring a developer for routine changes.

22. Practical Build Order - Database to UI

1. Freeze and back up the current production/staging database; document current schema and migration head.
2. Introduce tenant/legal entity/location/department/job/position master data cleanly, mapping existing employee rows without destructive replacement.
3. Separate person, employment and assignment concepts; create compatibility views/properties if old code expects employee fields.
4. Implement centralized permission checks and sensitivity classes before adding payroll or disciplinary data.
5. Implement audit/event history and effective-dated change services.

6. Create the workflow engine and migrate existing leave/other-request approvals onto it gradually.
7. Convert leave balances to a ledger while preserving opening balances as migration transactions.
8. Create private document storage abstraction and template/generated-document models.
9. Build design system components and refactor pages incrementally, starting with global shell, people list and employee profile.
10. Add time/attendance and payroll input interfaces, then payroll calculation/result/payslip flow.
11. Add talent/recruiting modules once the core worker/position/manager model is stable.
12. Add report builder/AI only after permissions and data semantics are trustworthy.

23. Feature Acceptance Matrix

Domain	Acceptance scope	Definition of done
People	Employee list, profile, history, org chart, positions, transfers/promotions/termination, bulk import/export	HR can see current and historical organization/employment state without inconsistent duplicate fields.
Leave	Policy, accrual, ledger, request, approve/reject, cancel/amend, calendar, attachments, reporting	Balance is mathematically reproducible from transactions.
Requests	Configurable types/forms, workflow, comments, SLA, attachments, notifications	New request categories can be added without new Python route/model each time.
Time	Shifts, punches/imports, corrections, attendance, overtime, payroll handoff	Every derived attendance result can be traced to source punches/schedule/rules.
Payroll	Comp history, periods, runs, validation, approval, lock, payslips, final settlement, export	An approved payroll is immutable and explainable; corrections are versioned.
Documents	Templates, preview, issue, private storage, expiry, acknowledgements	A previously issued PDF remains unchanged when template is edited.
Performance	Goals, reviews, feedback, 1:1s, calibration, PIP, succession	Cycle can be configured by HR and completed without spreadsheet side-processes.
Learning	Courses, enrollments, compliance due/expiry, certificates, skills	HR can show who is compliant and what is expiring.
Recruiting	Requisition, pipeline, interviews, offer, candidate conversion	Hire conversion creates worker once without re-entry/duplication.
Analytics	Role dashboards, standard reports, as-of reports, export, data quality	Report scope exactly matches user authorization.
Security	MFA-ready, RBAC/scope, audit, encryption/masking, secure files, logs	Unauthorized direct URL/API/file attempts fail server-side.
UX	Consistent shell/components, responsive, accessible, fast lists/forms	No module feels like a separate mini-app or generic CRUD page.

24. Research Sources and Standards

Primary emphasis was placed on official vendor, standards-body and UAE government sources current/recent as of the research date.

- [1] **Workday - Human Capital Management / HCM overview.** <https://www.workday.com/en-us/products/human-capital-management/overview.html>
- [2] **Workday - What is HCM software?.** <https://www.workday.com/en-us/topics/hr/human-capital-management-software.html>
- [3] **SAP - SuccessFactors HCM overview.** <https://www.sap.com/products/hcm/what-is-sap-successfactors.html>
- [4] **SAP - Performance & Goals.** <https://www.sap.com/mena/products/hcm/performance-goals.html>
- [5] **Oracle - Human Capital Management.** <https://www.oracle.com/human-capital-management/>
- [6] **Oracle - Human Resources.** <https://www.oracle.com/human-capital-management/human-resources/>
- [7] **Oracle - Journeys.** <https://www.oracle.com/human-capital-management/employee-experience/oracle-me/journeys/>
- [8] **Oracle - Payroll.** <https://www.oracle.com/human-capital-management/payroll/>
- [9] **Rippling - Product ecosystem.** <https://www.rippling.com/products>

- [10] **Rippling - Global HRIS.** <https://www.rippling.com/products/global/global-hris>
- [11] **Rippling - Performance Management.** <https://www.rippling.com/products/hr/performance-management>
- [12] **BambooHR - Platform.** <https://www.bamboohr.com/platform/>
- [13] **HiBob - HCM Platform.** <https://www.hibob.com/platform/>
- [14] **Deel - HR platform.** <https://www.deel.com/hr-platform/>
- [15] **Zoho People - Pricing/features.** <https://www.zoho.com/people/zohopeople-pricing.html>
- [16] **W3C - WCAG 2.2.** <https://www.w3.org/TR/WCAG22/>
- [17] **OWASP - Application Security Verification Standard.** <https://owasp.org/www-project-application-security-verification-standard/>
- [18] **NIST - SP 800-207 Zero Trust Architecture.** <https://csrc.nist.gov/pubs/sp/800/207/final>
- [19] **UAE Government - Employment laws and regulations in private sector.**
<https://u.ae/en/information-and-services/jobs/employment-in-the-private-sector/employment-laws-and-regulations-in-the-private-sector>
- [20] **UAE Government - Working hours and overtime.** <https://u.ae/en/information-and-services/jobs/employment-in-the-private-sector/working-hours>
- [21] **UAE Government - Annual leave.** <https://u.ae/en/information-and-services/jobs/employment-in-the-private-sector/types-of-leaves-and-entitlements-in-the-private-sector/annual-leave>
- [22] **MoHRE Labour Market Observatory - Wage Protection System.** <https://observatory.mohre.gov.ae/en/uae-labour-market-priorities/cutting-edge-labour-market-solutions>
- [23] **UAE Government - Data protection laws / PDPL.** <https://u.ae/en/about-the-uae/digital-uae/data/data-protection-laws>
- [24] **UAE Government - Visa and Emirates ID.** <https://u.ae/information-and-services/visa-and-emirates-id>

25. Final Product Recommendation

Build this as a platform, not a collection of pages The most important step is not adding 100 menu items. It is establishing a clean worker/organization/position model, effective dating, reusable workflows, permission scopes, audit, documents and a consistent design system. Once those foundations are correct, payroll, appraisals, recruiting, learning, service requests and AI can all share the same truth.

- Keep and upgrade the existing application; migrate deliberately rather than restarting.
- Prioritize Core HR + Permissions + Workflow + Audit + Documents before the glamorous modules.
- Treat payroll and employee identity data as high-risk engineering domains with maker-checker, tests and strict visibility.
- Make HR configuration possible from the product: policies, workflows, templates, fields, grades, components and request types.
- Use the proposed UI tokens/components as a product design system so every new screen looks like the same premium application.
- Build UAE localization as a country pack, not as hard-coded assumptions, so the same platform can later support other countries.
- Use Codex as an implementation accelerator under an inspection-first, migration-safe, test-driven protocol.

END OF BLUEPRINT